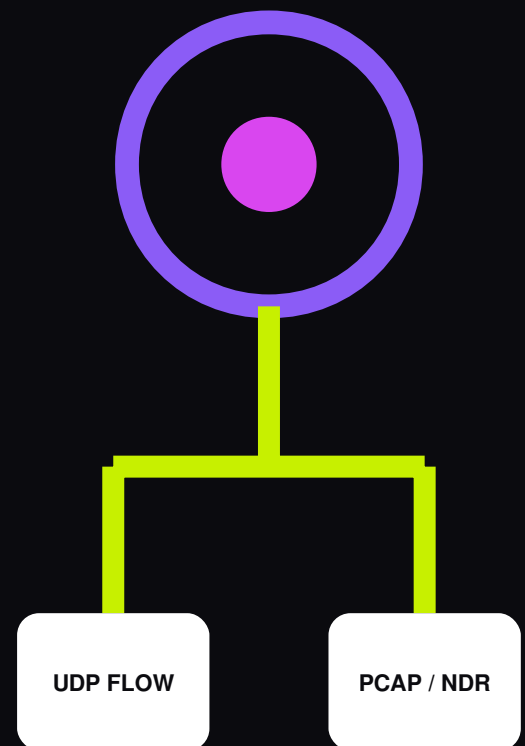


NETSCALER DTLS FRAGMENT VOLUME

Validates whether network telemetry can surface short high-volume UDP/DTLS sequences approaching the public CVE-2026-88772 laboratory traffic shape.

VALIDATION QUERY

CONFIDENCE: LOW-MEDIUM



EVIDENCE BEFORE ALERTING

REPORT DATE

5 October 2026

STATUS

Untested implementation
sketch

PRIMARY PLATFORM

Microsoft Sentinel

OPERATIONAL VALUE

7.2 / 10



EXECUTIVE ASSESSMENT

Decision, confidence and evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

7.2

Validates whether network telemetry can surface short high-volume UDP/DTLS sequences approaching the public CVE-2026-88772 laboratory traffic shape.

STATUS

Validation query

Untested implementation sketch; Confidence Low-Medium.

1primary table

0joins

0secondary rules

2validation gates

Evidence boundary

A result proves only a short high-volume UDP flow toward a configured NetScaler destination. Aggregated flow telemetry cannot prove malformed DTLS fragment metadata, memory corruption, denial of service, code execution, compromise, or attribution.



BEHAVIOR AND EVIDENCE

Observed facts separated from analytical scope.

MECHANICS

Source-supported fact

- 1 Citrix confirms exploitation of CVE-2026-88772; the precondition is DTLS enabled, which is the default on VPN virtual servers.
- 2 watchTowr reproduced control-flow hijacking and shellcode execution by overflowing a fixed 35,840-byte NSPPE scratch buffer during DTLS reassembly.
- 3 The published laboratory generator sends 120 malicious records totaling about 176,640 bytes after the DTLS cookie exchange.

Detection hypothesis

If an attacker sends a sequence resembling the published CVE-2026-88772 laboratory method, network telemetry may expose an unusually dense UDP/DTLS burst toward a NetScaler virtual server. Distinction requires NetScaler inventory, local baseline, and preferably packet-level DTLS inspection.

Unconfirmed elements

A result proves only a short high-volume UDP flow toward a configured NetScaler destination. Aggregated flow telemetry cannot prove malformed DTLS fragment metadata, memory corruption, denial of service, code execution, compromise, or attribution.

Logic: Network-volume approximation requiring packet-level confirmation **ATT&CK:** T1190



TELEMETRY CONTRACT

Collection prerequisites and field reliability.

TELEMETRY

REQUIRED

Perimeter firewall, NDR, or other CEF telemetry in CommonSecurityLog with UDP protocol, source/destination IP, destination port, event count, and byte fields.

OPTIONAL ENRICHMENT

NetScaler destination inventory, NAT mapping, PCAP, DTLS-aware NDR parsing, NSPPE crash/restart evidence, core files, NetScaler Console IoC results, FIM, and appliance build/configuration state.

Fields	Reliability	Use
TimeGenerated, SourceIP, DestinationIP	Documented	Query or triage
Protocol, DestinationPort	Documented	Query or triage
SentBytes, ReceivedBytes	Environment-dependent	Query or triage
DeviceVendor, DeviceProduct, DeviceAction	Documented	Query or triage
NetScaler destination inventory	Required tuning	Query or triage
DTLS fragment metadata	Unavailable in flow logs	Query or triage

Excluded

No claim of malformed DTLS fragments, memory corruption, RCE, denial of service, actor attribution, or universal exploit thresholds is made.



PRIMARY KQL

Direct source-supported conditions with investigable output.

VALIDATION

STATUS

Validation query — Untested implementation sketch

```
KQL - UNTESTED

// MITRE ATT&CK: T1190
// Validation query - Untested implementation sketch
// CVE: CVE-2026-88772
// Primary platform: Microsoft Sentinel / Log Analytics
// Required telemetry: perimeter/network CEF records in CommonSecurityLog
// Required tuning: populate NetScalerDestinationIPs with the public or translated
// destination IPs of managed NetScaler ADC/Gateway appliances.
// Detection boundary: approximates the watchTower test shape (many UDP/DTLS records
// and high byte volume in a short interval). It cannot parse DTLS handshake fragment
// headers and therefore cannot confirm the vulnerable NSB-chain condition.
let Lookback = 14d;
let Window = 1m;
let NetScalerDestinationIPs = dynamic([
    // "203.0.113.10"
]);
CommonSecurityLog
| where TimeGenerated >= ago(Lookback)
| where Protocol == "UDP"
| where DestinationPort in (443, 8443, 9462)
| where array_length(NetScalerDestinationIPs) == 0 or DestinationIP in (NetScalerDestinationIPs)
| extend EventBytes = coalesce(tolong(SentBytes), 0) + coalesce(tolong(ReceivedBytes), 0)
| summarize
    FirstSeen=min(TimeGenerated),
    LastSeen=max(TimeGenerated),
    NetworkEvents=count(),
    TotalBytes=sum(EventBytes),
    DeviceVendors=make_set(DeviceVendor, 5),
    DeviceProducts=make_set(DeviceProduct, 5),
    Actions=make_set(DeviceAction, 10)
    by SourceIP, DestinationIP, DestinationPort, bin(TimeGenerated, Window)
| where NetworkEvents >= 120 or TotalBytes >= 176640
| extend
    ResearchShape_RecordCount = NetworkEvents >= 120,
    ResearchShape_ByteVolume = TotalBytes >= 176640
| project
    TimeGenerated,
    FirstSeen,
    LastSeen,
    SourceIP,
    DestinationIP,
    DestinationPort,
    NetworkEvents,
    TotalBytes,
    ResearchShape_RecordCount,
    ResearchShape_ByteVolume,
    DeviceVendors,
    DeviceProducts,
    Actions
| order by TimeGenerated desc
```

WINDOW
1 minute

CANDIDATE
THRESHOLD

>=120 events or
>=176,640 bytes

RESEARCH
PROXIMITY

>=120 events /
>=176,640 bytes

SCOPE

Known NetScaler
destination IPs only



TRIAGE AND TUNING

Human validation before response.

WORKFLOW

1

Preserve

Retain raw CEF records, flow identifiers, source/destination IP and port, counts, byte fields, appliance logs, crash evidence, and available packet captures.

2

Confirm

Confirm destination ownership, NAT mapping, DTLS configuration, appliance build, source ownership, scanning authorization, and packet-retention availability.

3

Enrich

NetScaler destination inventory, NAT mapping, PCAP, DTLS-aware NDR parsing, NSPPE crash/restart evidence, core files, NetScaler Console IoC results, FIM, and appliance build/configuration state.

4

Scope

Review PCAP/NDR DTLS structure, NSPPE stability, core/crash artifacts, Console IoC/FIM results, service impact, and adjacent appliance changes.

Expected benign overlap

Legitimate DTLS VPN throughput, reconnect or retransmission storms, vulnerability scanning, red-team tests, performance testing, and unrelated UDP services sharing the selected destination ports.

Response boundary

A result proves only a short high-volume UDP flow toward a configured NetScaler destination. Aggregated flow telemetry cannot prove malformed DTLS fragment metadata, memory corruption, denial of service, code execution, compromise, or attribution.



VALIDATION GATES

Controlled tests and cross-SIEM limits.

QUALITY CONTROL

Validation steps

1. Populate the NetScaler destination-IP inventory and verify NAT direction, destination port, and CEF byte semantics.
2. Baseline ordinary VPN login, steady-state sessions, reconnect storms, upgrades, health checks, and load tests.
3. Where PCAP exists, validate record count, handshake length, message sequence, fragment offsets, and inconsistent fragment lengths.
4. Correlate candidates with NSPPE crash/restart, core artifacts, NetScaler Console IoC/FIM, and post-exploitation evidence.

Decision criteria

Success: A controlled laboratory flow is visible, normal VPN traffic is characterized, and candidates retain enough packet or appliance evidence for confirmation.

Rejection: Legitimate DTLS activity dominates the threshold and no packet-aware or appliance-side confirmation is available.

Failure: Missing NetScaler inventory, NAT ambiguity, sampled/aggregated flows, absent byte fields, encrypted protocol blindness, or no retained PCAP.

Platform	Decision	Missing evidence
Microsoft Sentinel	Validation query	Network visibility and baseline
Splunk	No reliable implementation	Index, sourcetype, parser, sample
Chronicle	No reliable implementation	Parser and exact UDM mapping



CONCLUSION AND REFERENCES

Coverage statement and document control.

FINAL

CONCLUSION

Validation query

Validates whether network telemetry can surface short high-volume UDP/DTLS sequences approaching the public CVE-2026-88772 laboratory traffic shape.

A result proves only a short high-volume UDP flow toward a configured NetScaler destination. Aggregated flow telemetry cannot prove malformed DTLS fragment metadata, memory corruption, denial of service, code execution, compromise, or attribution.

MITRE ATT&CK

T1190

References

1. Citrix - CTX697096 - published 27 Sep 2026
2. NetScaler Cyber Threat Intelligence - CVE-2026-88771 through CVE-2026-88778 - updated 30 Sep 2026
3. watchTower Labs - NetScaler DTLS Preauth Memory Overflow CVE-2026-88772 - 29 Sep 2026
4. UK NCSC - Exploitation of vulnerabilities affecting NetScaler - 28 Sep 2026
5. Microsoft Learn - CommonSecurityLog schema
6. MITRE ATT&CK - T1190

Document control

English dossier. No customer data. URLs are defanged in references.txt. HTML and rendering assets remain private.